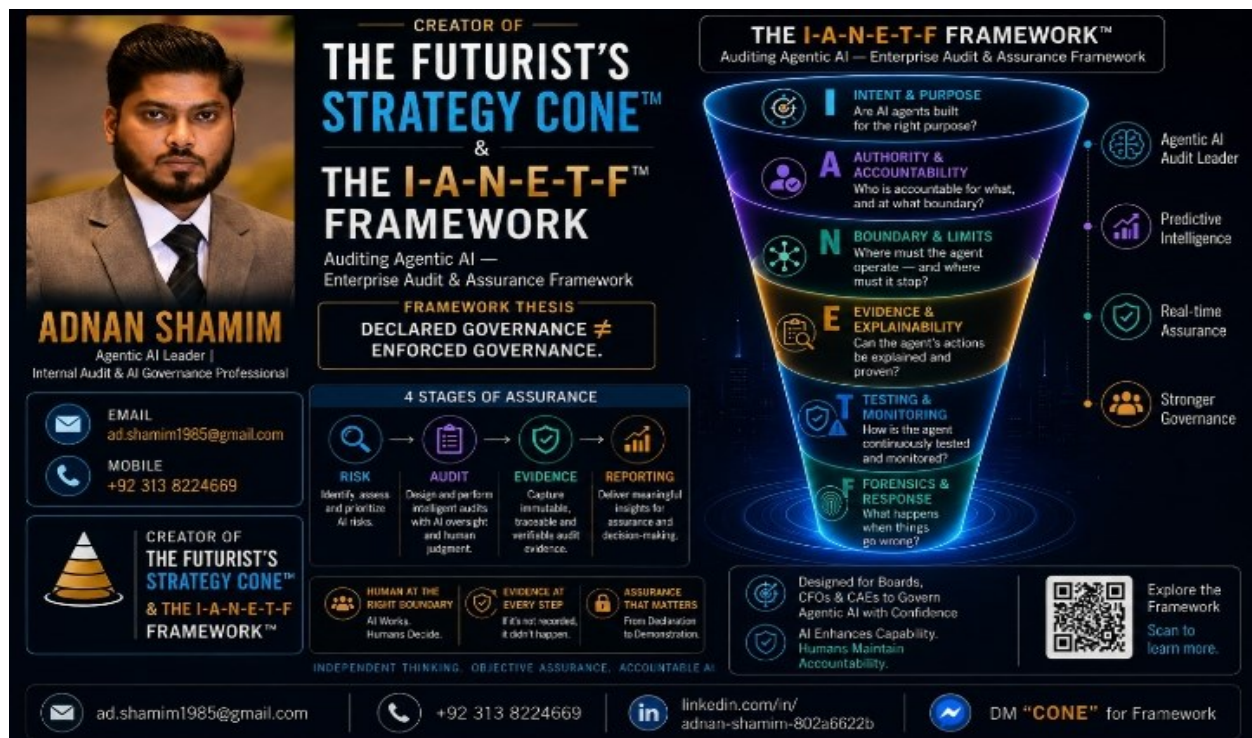




From Documented Controls to Defensible Assurance

A Rigorous Control-Universe, Evidence, Change and Independent-Assurance Model for Agent AI

Moving from documented intent to demonstrable, evidence-based governance

As organizations move from conventional automation toward Agent AI, the control environment becomes increasingly dynamic.

Agents can make decisions, invoke tools, access data, interact with other agents, operate under changing permissions, and execute consequential actions within defined or changing decision boundaries.

That changes the assurance question.

It is no longer sufficient to ask:

“Do we have the control?”

The stronger question is:

“Can we independently demonstrate, for the defined assurance objective and relevant period, that the appropriate control was defined and authorized, sufficiently represented in the relevant control universe, implemented as intended, actually operated within its authorized boundary, supported by sufficient appropriate evidence, and that material changes and exceptions were identified and evaluated?”

That is the difference between **documented governance** and **defensible assurance**.

1. The Foundational Distinction: Documentation Is Not Operation

A policy, procedure, risk-control matrix, control repository or governance document can establish what management **defines, expects or authorizes**.

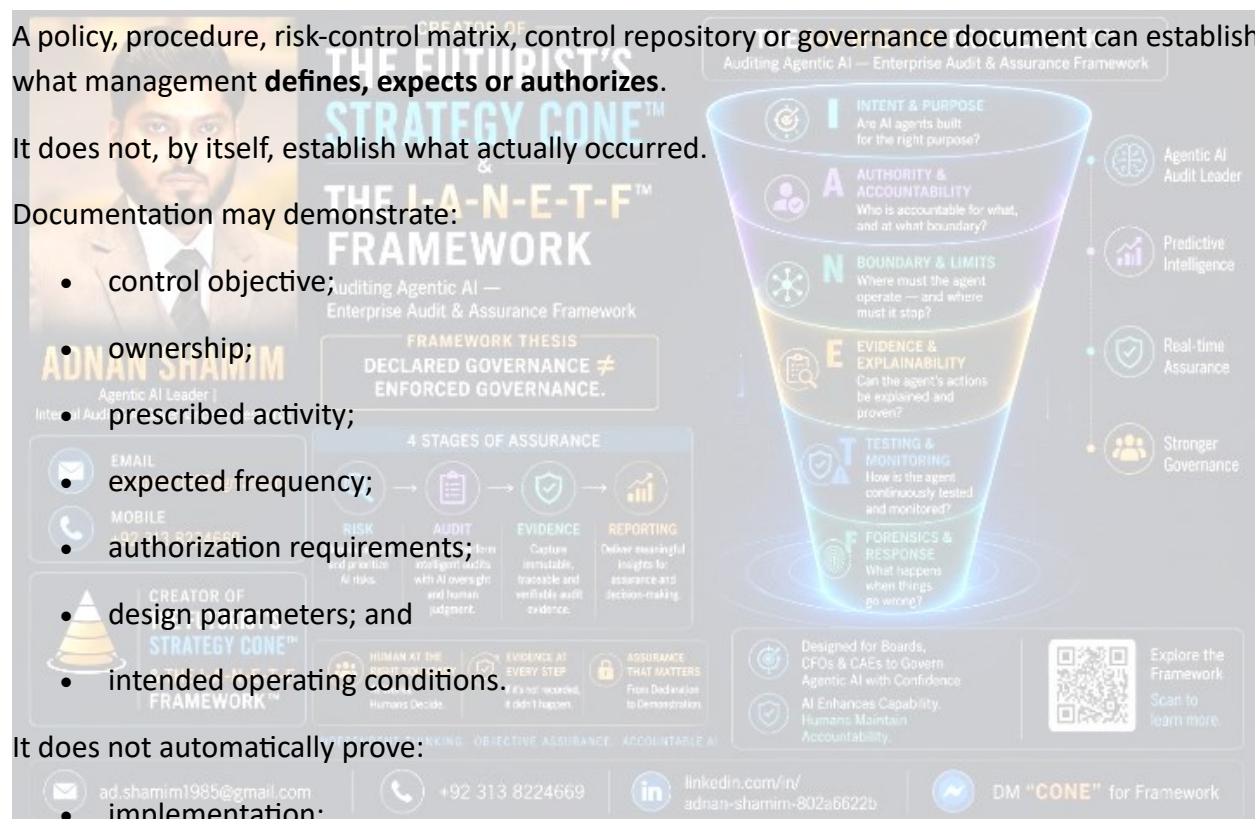
It does not, by itself, establish what actually occurred.

Documentation may demonstrate:

- control objective;
- ownership;
- prescribed activity;
- expected frequency;
- authorization requirements;
- design parameters; and
- intended operating conditions.

It does not automatically prove:

- actual execution;
- execution at the required frequency;
- execution by the authorized party;
- operation within the authorized boundary;
- effectiveness;
- continuity throughout the relevant period; or



- absence of unauthorized bypass.

Therefore:

Control existence is not control operation.

And:

Control design evidence is not, by itself, evidence of operating effectiveness.

The assurance question must therefore move beyond:

“Is the control documented?”

to:

“Did the control operate as required, by the appropriate authority, within the applicable boundary, during the relevant period?”

2. The Assurance Assertion Must Be Defined First

No control conclusion should be stronger than the assertion being tested.

Before testing, the assurance objective should establish, as applicable:

- **scope** — what is included and excluded;
- **criterion** — what should be true;
- **control objective** — what risk the control is intended to address;
- **relevant period** — when the assertion applies;
- **population/state** — what is being assessed;
- **evidence requirements** — what would support the assertion;
- **testing methodology** — how the assertion will be evaluated; and
- **limitations** — what the evidence or method cannot establish.

This creates a fundamental chain:

Assertion → Criterion → Evidence → Test → Conclusion

Without that chain, an assurance conclusion risks becoming an unsupported assertion itself.

3. Evidence Has Different Purposes

Evidence that identifies or describes a control is not necessarily evidence that proves its operation.

Consider an Agentic AI requirement:

High-risk decisions require human approval before execution.

That establishes an expected governance condition.

It does not automatically prove that:

- the threshold was technically enforced;
- the agent stopped at the threshold;
- the designated human approved the decision;
- the approver had appropriate authority;
- the approval was connected to the actual decision;
- the agent could not bypass the approval;
- the resulting action remained within the authorized boundary; or
- the control operated consistently throughout the relevant period.

Those conclusions require evidence appropriate to the specific assertion.

Therefore:

Authorized Control Definition



Implementation



Execution



Evidence

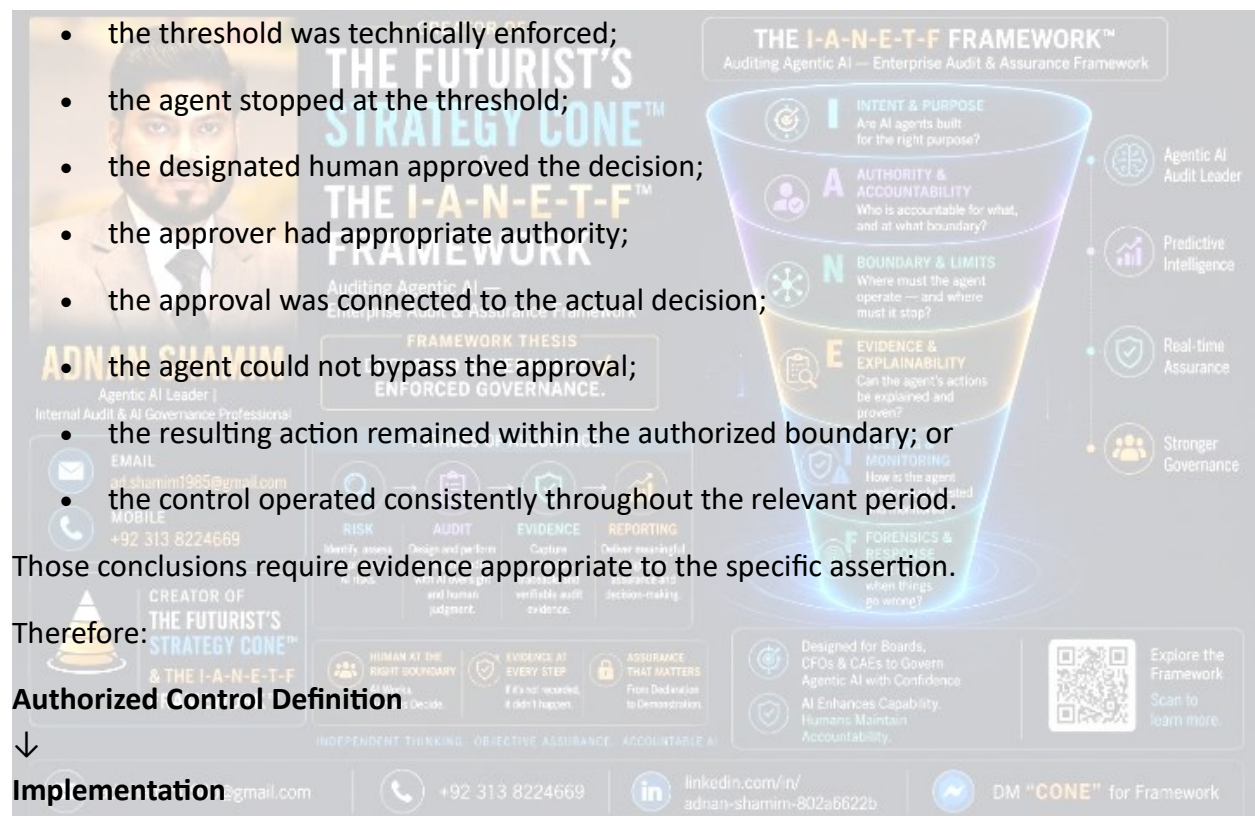


Independent Testing



Assurance Conclusion

Each stage answers a different assurance question.



4. Evidence of Absence vs. Absence of Evidence

This distinction must be explicit.

Evidence of absence

Reliable evidence demonstrates that the relevant control, action, event or condition did not occur.

Absence of evidence

The expected evidence was not located, was unavailable, was incomplete, or could not be reliably retrieved.

These are not automatically equivalent.

Therefore:

Absence of evidence is not automatically evidence that the control did not operate.

However, if the control objective specifically requires the existence of an evidentiary record, failure to produce required evidence may itself represent a control or record-retention deficiency.

The conclusion must therefore follow the **specific control objective and evidence requirement**, rather than an automatic assumption.

5. The Control Universe Problem

Every comparison requires a comparison basis.

Suppose an organization maintains 500 documented controls.

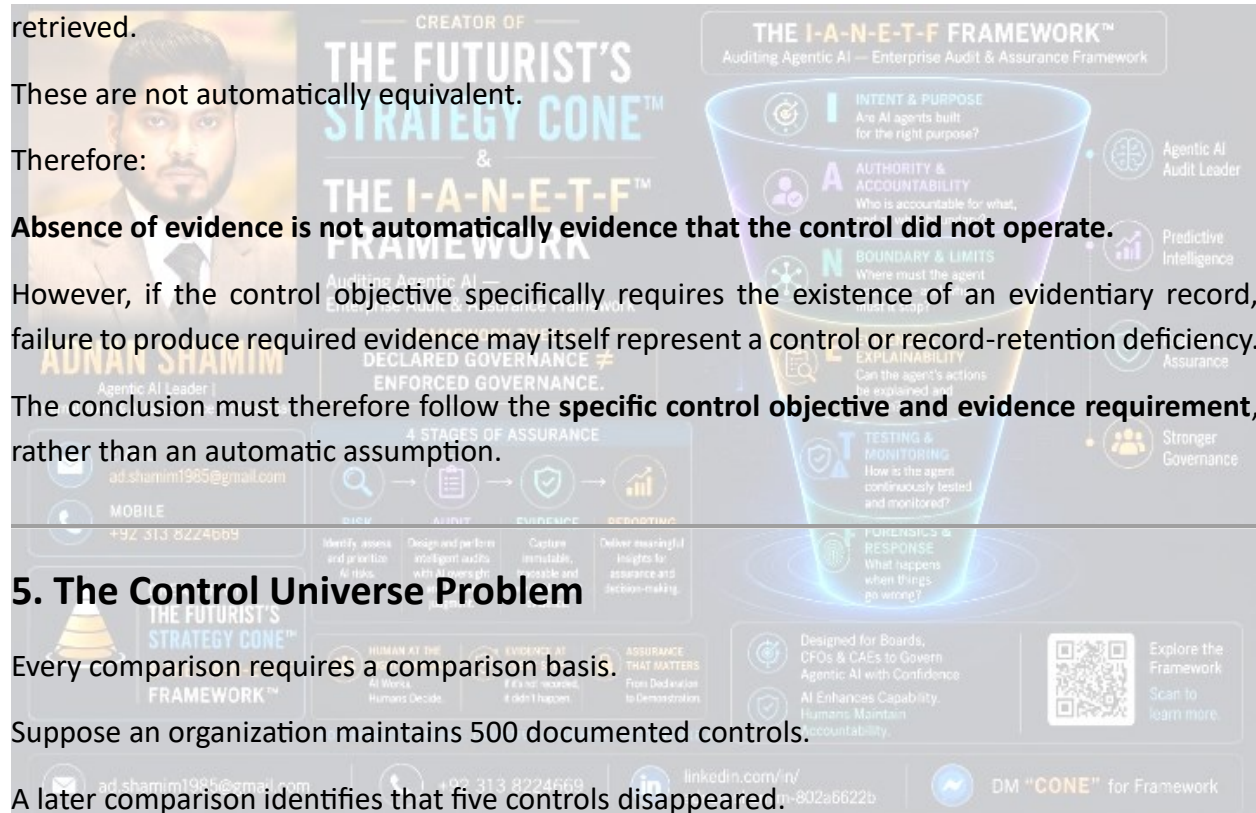
A later comparison identifies that five controls disappeared:

The comparison establishes a potential change **within the represented baseline**.

It does not, by itself, establish that the 500-control universe was complete.

Controls may have been:

- required but never documented;
- implemented outside the formal repository;
- embedded in system configuration;



- automated;
- embedded within workflows;
- implemented through technical guardrails;
- introduced without proper documentation; or
- removed before the baseline was established.

Therefore:

A comparison can identify change within its represented universe; it cannot, by itself, prove that the represented universe contains every control relevant to the assurance objective.

This is a fundamental distinction.

6. Universe Completeness Is Assertion-Specific

Absolute completeness should not be claimed without defining what “complete” means.

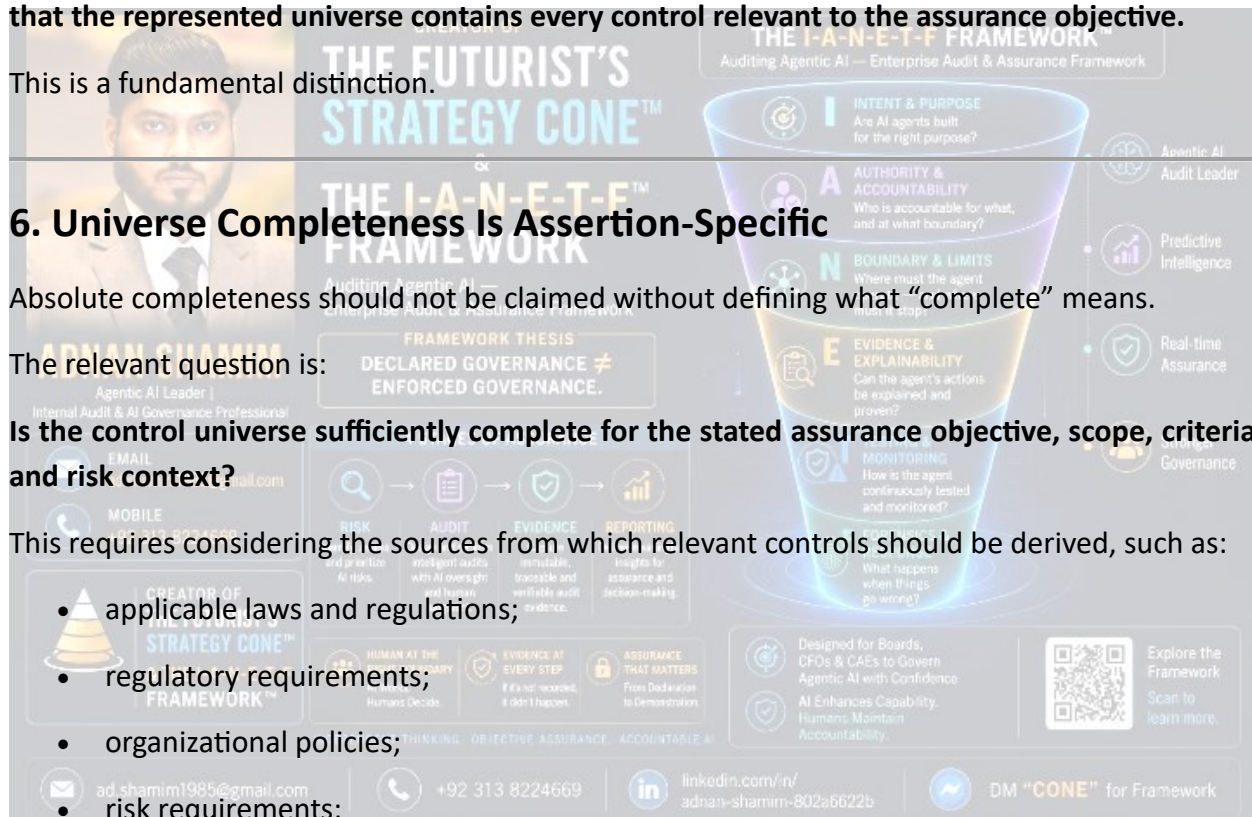
The relevant question is:

Is the control universe sufficiently complete for the stated assurance objective, scope, criteria and risk context?

This requires considering the sources from which relevant controls should be derived, such as:

- applicable laws and regulations;
- regulatory requirements;
- organizational policies;
- risk requirements;

- business processes;
- technology architecture;
- system configurations;
- security requirements;
- AI governance requirements;
- decision boundaries;



- human-oversight requirements;
- automated controls;
- technical guardrails;
- agent permissions;
- tool-access restrictions; and
- other relevant control mechanisms.

The authoritative universe therefore represents **the controls relevant to the defined assurance objective**, not merely whatever happens to be recorded in a repository.

7. Three Distinct Completeness Questions

“Completeness” should be separated into distinct assurance dimensions.

A. Universe Completeness

Have we identified the relevant controls that should exist for the stated scope and objective?

B. State Completeness

Have we sufficiently captured the relevant control states that existed or operated during the relevant period?

C. Evidence Completeness

Do we have sufficient appropriate evidence to support the specific assurance assertion?

These questions are related but not interchangeable.

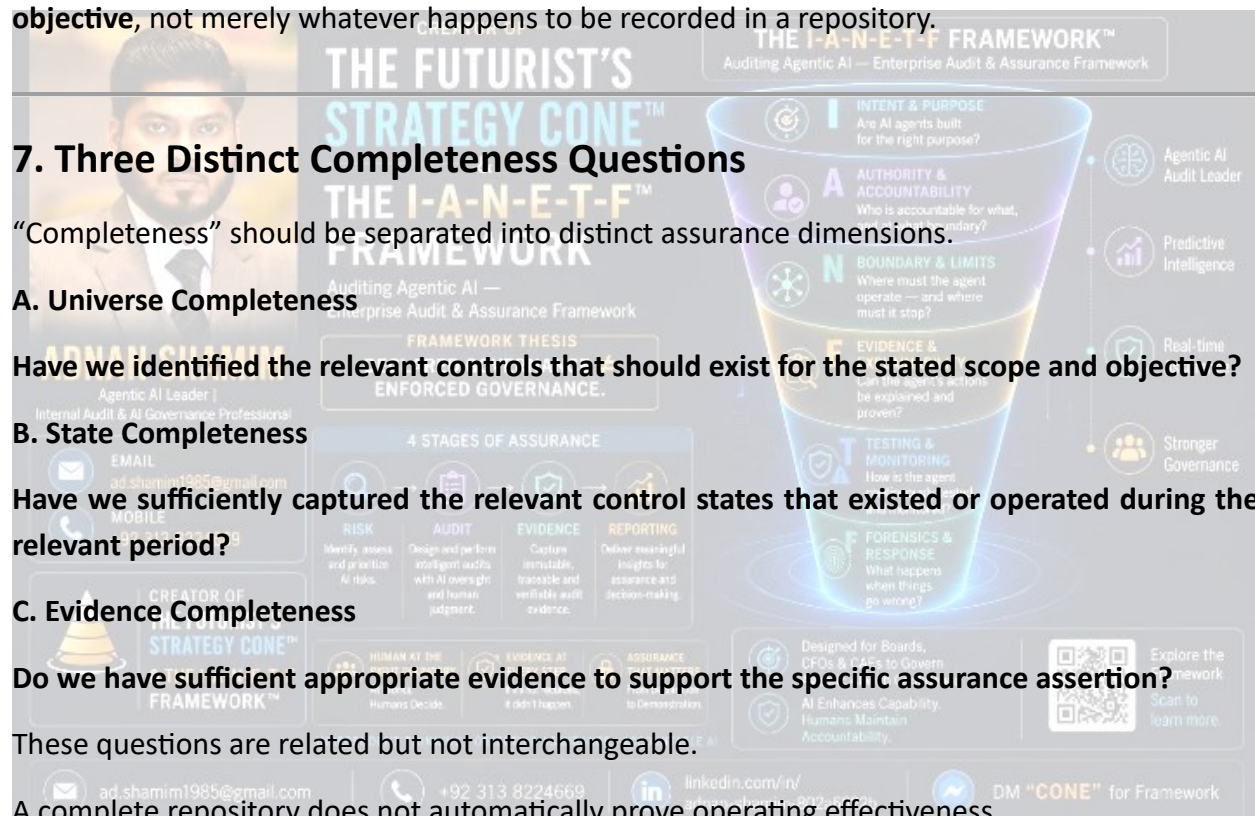
A complete repository does not automatically prove operating effectiveness.

A large evidence population does not automatically prove universe completeness.

A current state does not automatically prove historical operation.

Therefore:

Universe completeness, state completeness and evidence completeness must be assessed separately and connected through a defined assurance methodology.



8. Expected State vs. Observed State

A mature assurance model distinguishes:

Expected State

What should exist or operate according to the applicable authority, criteria and control objective.

Implemented State

How the control has actually been configured or deployed.

Observed State

What reliable evidence demonstrates actually existed or occurred.

These states may align.

They may also differ.

For example:

Expected: Human approval is mandatory above a defined risk threshold.

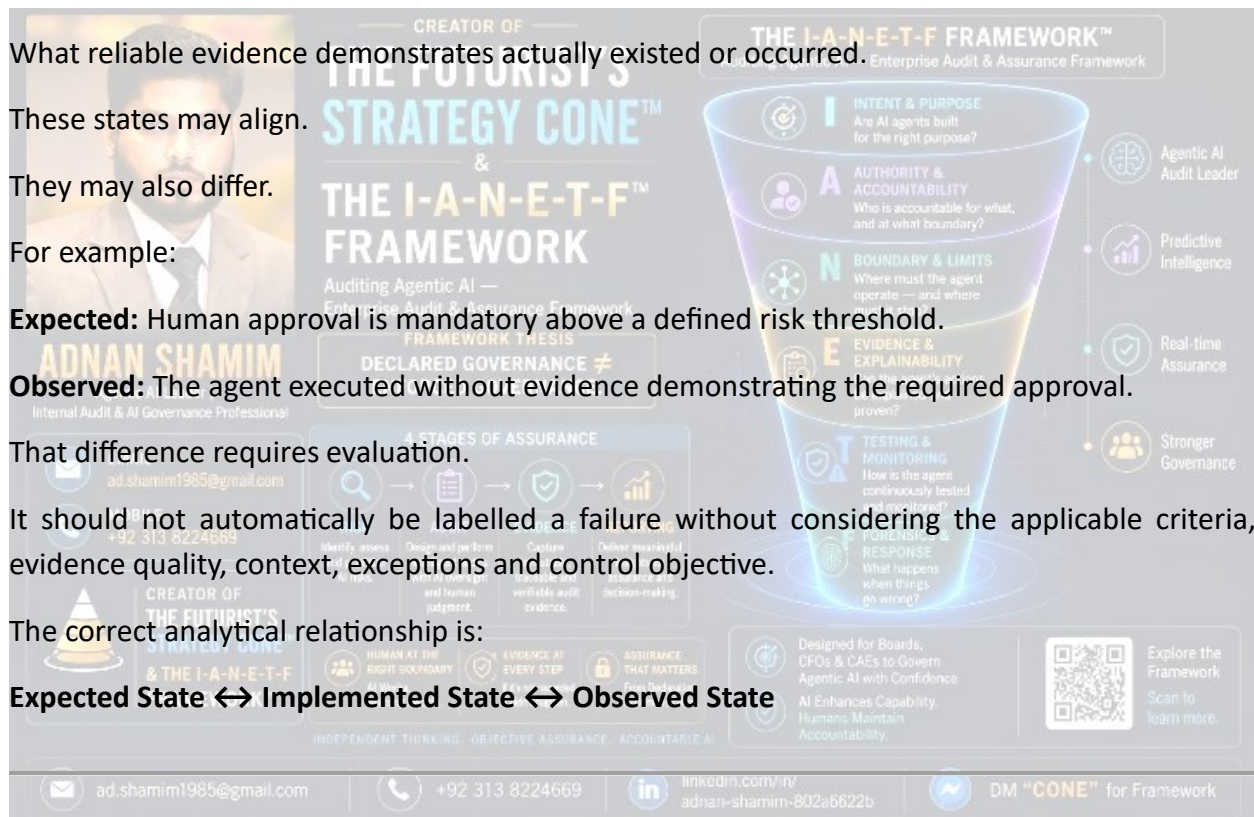
Observed: The agent executed without evidence demonstrating the required approval.

That difference requires evaluation.

It should not automatically be labelled a failure without considering the applicable criteria, evidence quality, context, exceptions and control objective.

The correct analytical relationship is:

Expected State ↔ Implemented State ↔ Observed State



9. Current State Is Not Historical Proof

A control observed today does not automatically establish that it operated yesterday.

Evidence that a control operated yesterday does not automatically establish that it continues to operate today.

For period-based assurance, the evidence must be appropriate to the **period and assertion being tested**.

This becomes particularly important in Agentic AI because the environment may change through:

- model updates;
- configuration changes;
- policy changes;
- permission changes;
- tool changes;
- instruction or prompt changes;
- infrastructure changes;

- integration changes;
- agent-to-agent interactions; and
- decision-boundary changes.

Therefore:

A point-in-time observation establishes a state at that point in time. It does not, without appropriate additional evidence, establish sustained operation across an entire period.

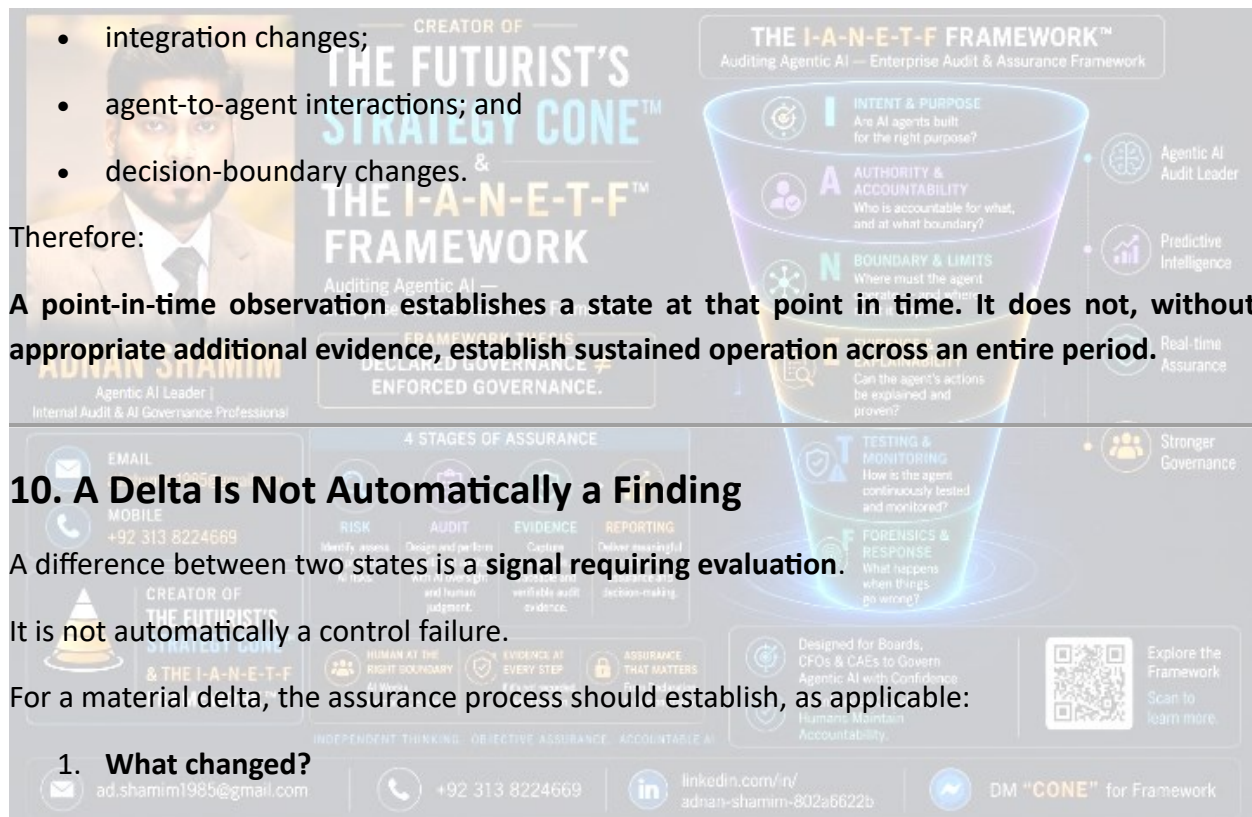
10. A Delta Is Not Automatically a Finding

A difference between two states is a **signal requiring evaluation**.

It is not automatically a control failure.

For a material delta, the assurance process should establish, as applicable:

1. **What changed?**
2. **When did it change?**
3. **What was the authorized state?**
4. **What was the expected state?**
5. **What was the observed state?**
6. **Was the change authorized?**
7. **Was it implemented appropriately?**
8. **Was it adequately evidenced?**



9. Did it affect the control objective or risk?
10. Was the resulting state within the authorized boundary?
11. What conclusion does the evidence support?

Thus:

Detection of a difference is not automatically proof of a control failure.

The delta must be evaluated against the relevant criteria and evidence.

11. No Detected Delta Is Not Proof of No Change

The reverse problem is equally important.

A system may report no detected change because:

- the universe was incomplete;
- historical evidence was unavailable;
- the detection mechanism lacked coverage;
- the relevant change was outside the monitored population;
- the evidence was unreliable; or
- the change was not technically observable through the selected method.

Therefore:

No detected change is not automatically proof that no change occurred.

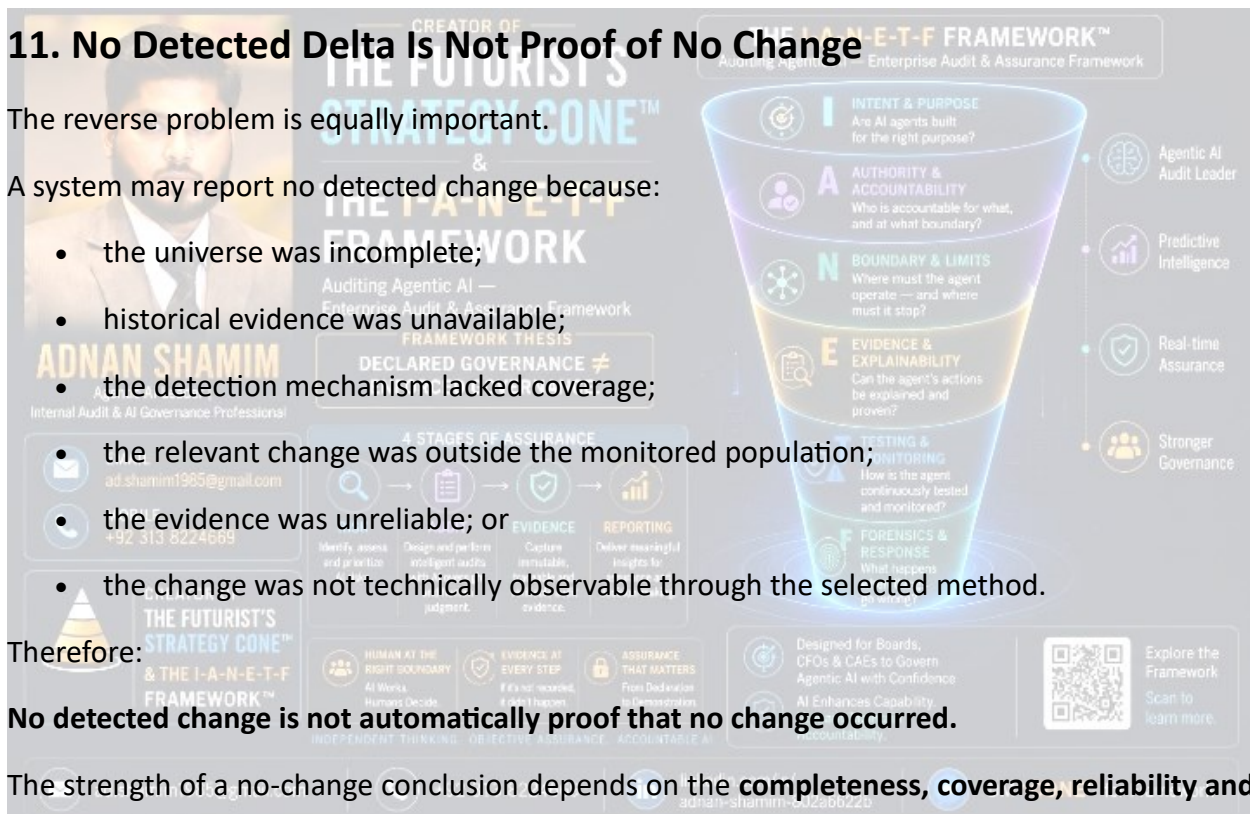
The strength of a no-change conclusion depends on the **completeness, coverage, reliability and capability of the detection process.**

12. Agentic AI Makes Control States Dynamic

Agentic AI introduces additional control dimensions.

An agent may:

- interpret information;
- make decisions;



- invoke tools;
- access data;
- interact with APIs;
- initiate actions;
- collaborate with other agents;
- operate under confidence thresholds;
- escalate to humans; and
- act within dynamic decision boundaries.

The relevant control universe may therefore include:

Authority → Permissions → Decision Boundaries → Model Constraints → Tool Restrictions → Human Oversight → Execution Controls → Monitoring → Revocation → Evidence

This means AI governance cannot depend exclusively on static policies and repositories.

The assurance architecture must be capable of evaluating **dynamic control states**.

13. Effective Revocation Must Be Demonstrable

A documented emergency-stop procedure establishes an intended control.

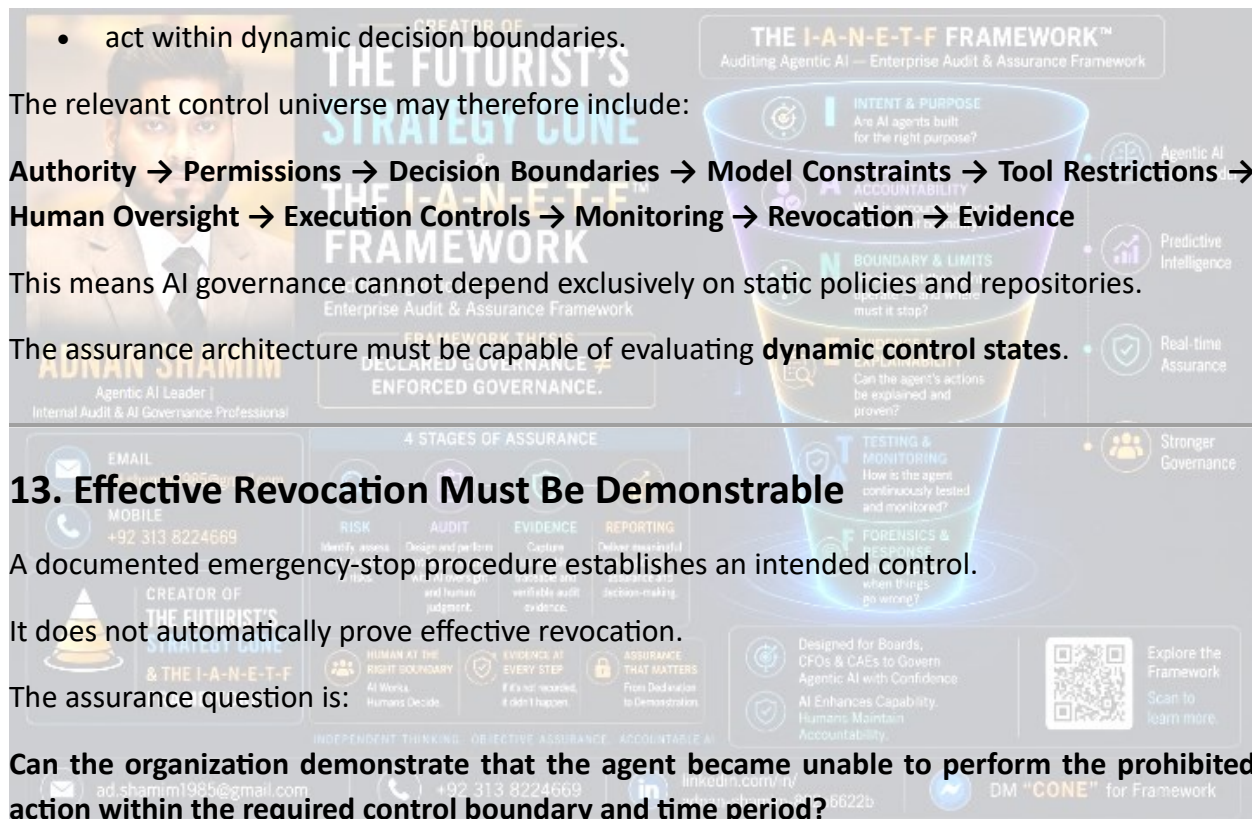
It does not automatically prove effective revocation.

The assurance question is:

Can the organization demonstrate that the agent became unable to perform the prohibited action within the required control boundary and time period?

Depending on the control objective, relevant evidence may need to demonstrate that:

- authorization was revoked;
- relevant permissions were removed or blocked;
- execution paths were appropriately contained;
- tool access was prevented;
- downstream execution was prevented where required;



- subsequent prohibited actions were rejected; and
- the required revocation time was achieved.

The principle is:

The assurance objective is not merely to prove that a stop instruction was issued. It is to establish whether the control produced the required effect.

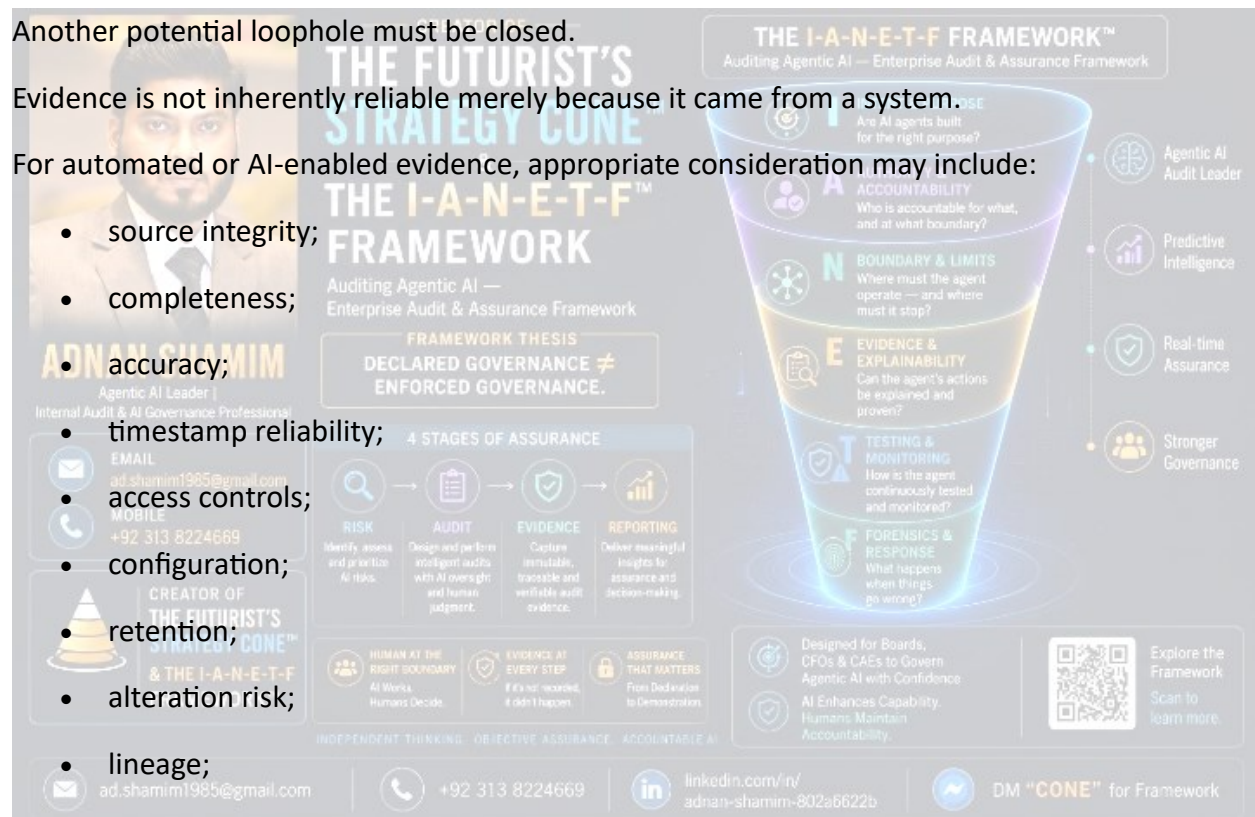
14. System-Generated Evidence Is Not Automatically Reliable

Another potential loophole must be closed.

Evidence is not inherently reliable merely because it came from a system.

For automated or AI-enabled evidence, appropriate consideration may include:

- source integrity;
- completeness;
- accuracy;
- timestamp reliability;
- access controls;
- configuration;
- retention;
- alteration risk;



- lineage;
- independence;
- population coverage; and
- whether the evidence-generating mechanism itself was appropriately controlled.

Likewise:

AI-generated evidence is not self-authenticating.

Its reliability must be evaluated according to the assurance objective and the nature of the evidence.

15. Management Accountability and Internal Audit Independence

Management is responsible for operating controls within its responsibilities.

Internal Audit provides independent assurance within its approved mandate.

Accordingly, Internal Audit should distinguish:

Management Assertion

→ What management says occurred.

Management Evidence

→ What management provides to support the assertion.

Audit Evaluation

→ How Internal Audit evaluates the evidence.

Independent Assurance Conclusion

→ What Internal Audit can reasonably and defensibly conclude.

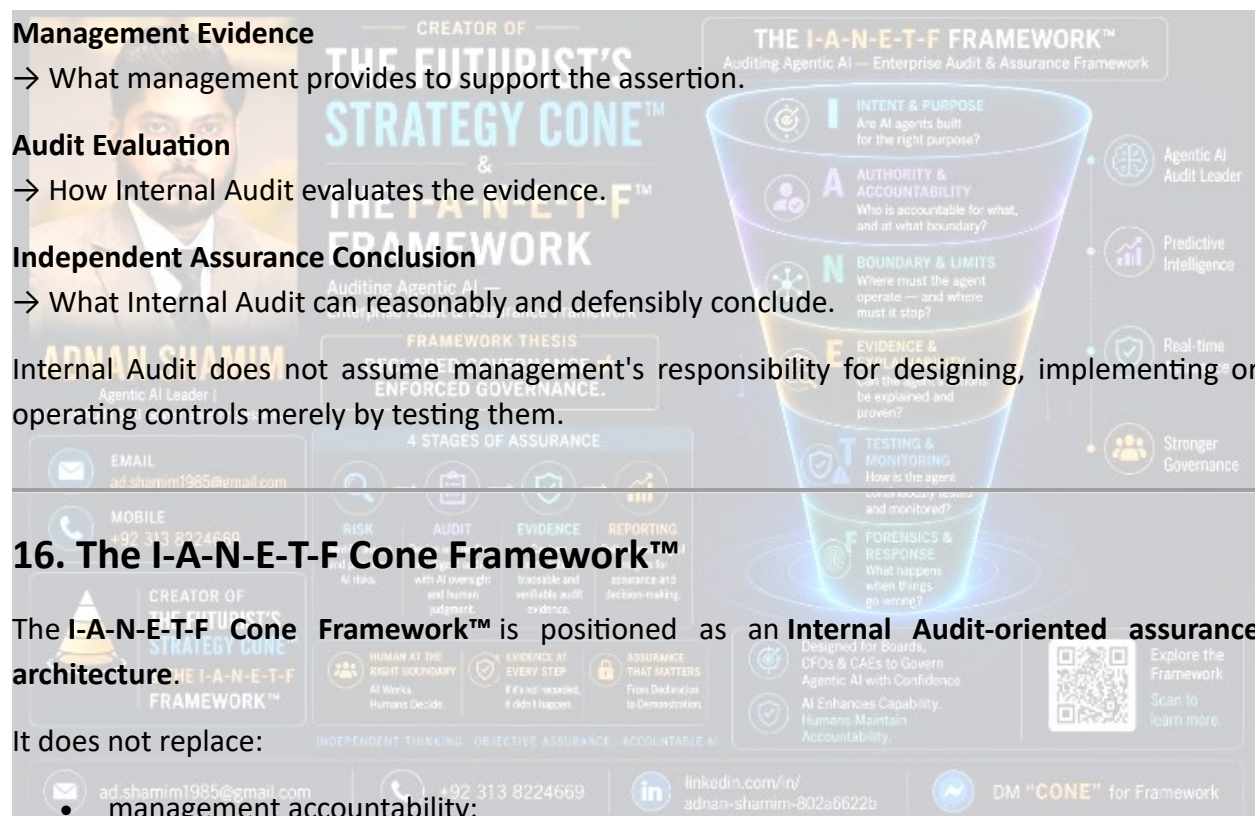
Internal Audit does not assume management's responsibility for designing, implementing or operating controls merely by testing them.

16. The I-A-N-E-T-F Cone Framework™

The I-A-N-E-T-F Cone Framework™ is positioned as an Internal Audit-oriented assurance architecture

It does not replace:

- governance;
- risk management;
- operational controls;
- regulatory obligations;
- control frameworks; or
- management's responsibility for remediation.



Its role is to establish a structured assurance chain.

I — Identify

Identify the relevant control universe, risks, obligations, criteria, control objectives, scope and assurance boundaries.

A — Assess

Assess design, authority, risk relevance, implementation requirements and expected operating conditions.

N — Navigate

Trace the control from its defined requirement into the actual process, system, agent, decision boundary and evidence environment.

E — Evaluate

Evaluate whether the observed evidence is relevant, reliable, sufficient and appropriate for the assertion being tested.

T — Test

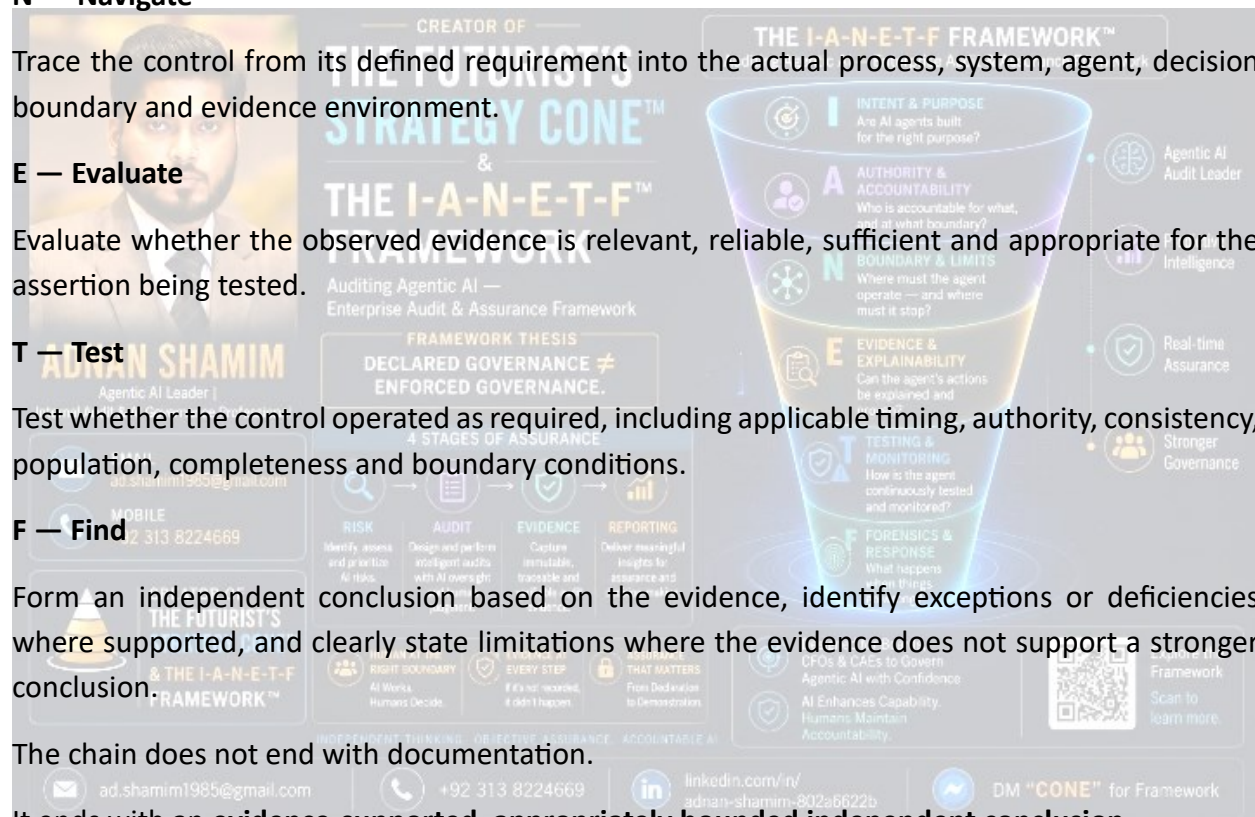
Test whether the control operated as required, including applicable timing, authority, consistency, population, completeness and boundary conditions.

F — Find

Form an independent conclusion based on the evidence, identify exceptions or deficiencies where supported, and clearly state limitations where the evidence does not support a stronger conclusion.

The chain does not end with documentation.

It ends with an **evidence-supported, appropriately bounded independent conclusion.**



17. The Integrated Assurance Architecture

The complete model can be expressed as:

ASSURANCE OBJECTIVE

What exactly are we trying to establish?



SCOPE & CRITERIA

What is included, excluded and against what standard?



AUTHORITATIVE CONTROL UNIVERSE

What relevant controls should exist?



EXPECTED CONTROL STATE

What should each control do?



IMPLEMENTED STATE

How is the control actually configured or deployed?



OBSERVED OPERATING STATE

What does reliable evidence demonstrate?



HISTORICAL / PRIOR STATE

What evidence demonstrates the relevant prior condition?



DELTA ANALYSIS

What changed, disappeared, emerged, degraded or became unauthorized?



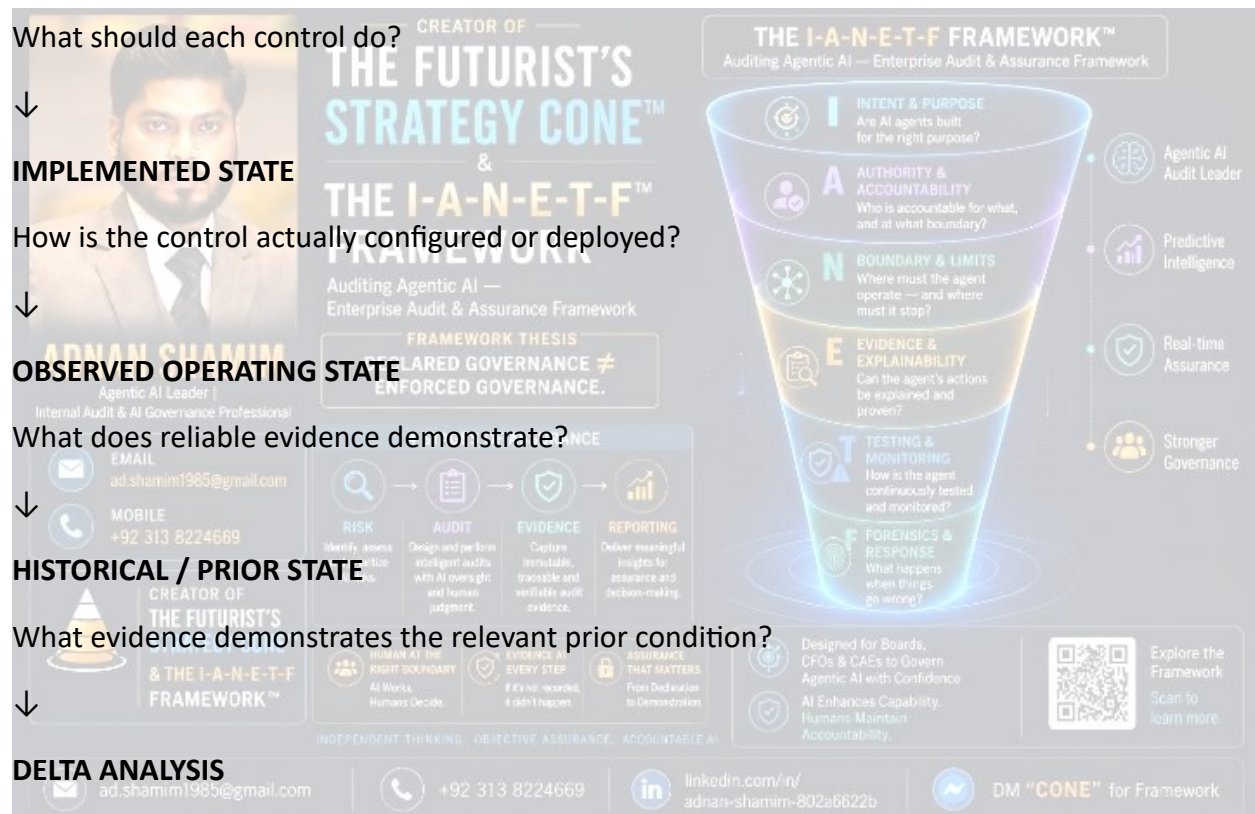
EVIDENCE VALIDATION

Is the evidence sufficient, appropriate, reliable and relevant?



INDEPENDENT TESTING

Did the control operate as required?





EXCEPTION & LIMITATION ASSESSMENT

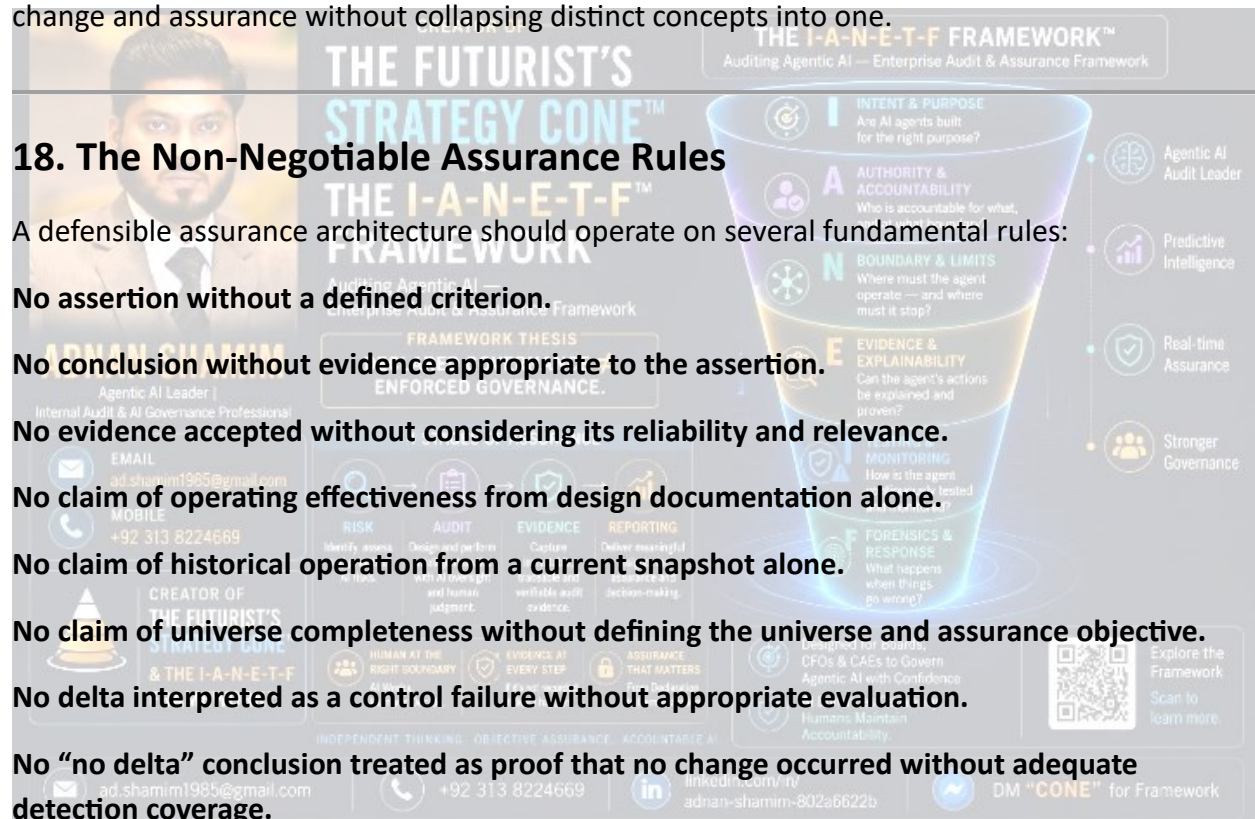
What is supported, what is not supported, and what remains uncertain?



ASSURANCE CONCLUSION

What can Internal Audit independently and defensibly conclude?

This architecture connects governance, control design, implementation, operation, evidence, change and assurance without collapsing distinct concepts into one.



No absence of evidence automatically treated as evidence of absence.

No system-generated or AI-generated evidence treated as inherently reliable.

No management assertion substituted for independent audit evaluation.

No assurance conclusion stronger than the evidence legitimately supports.

These rules create the discipline necessary for defensible assurance.

19. What the Model Does Not Claim

A technically defensible framework must define its boundaries.

It does **not** claim that:

- every undocumented activity is automatically a control deficiency;
- every change is automatically a control failure;
- every missing record proves non-operation;
- a historical snapshot proves continuous operation without appropriate evidence;
- a control repository is automatically authoritative;
- absence of a detected change proves absence of change;
- system-generated evidence is automatically reliable;
- evidence alone eliminates professional judgment; or
- Internal Audit assumes management's responsibility for operating controls.

Instead, the framework provides a disciplined basis for determining whether the evidence supports the **specific assurance conclusion being made**.

20. The Core Assurance Test

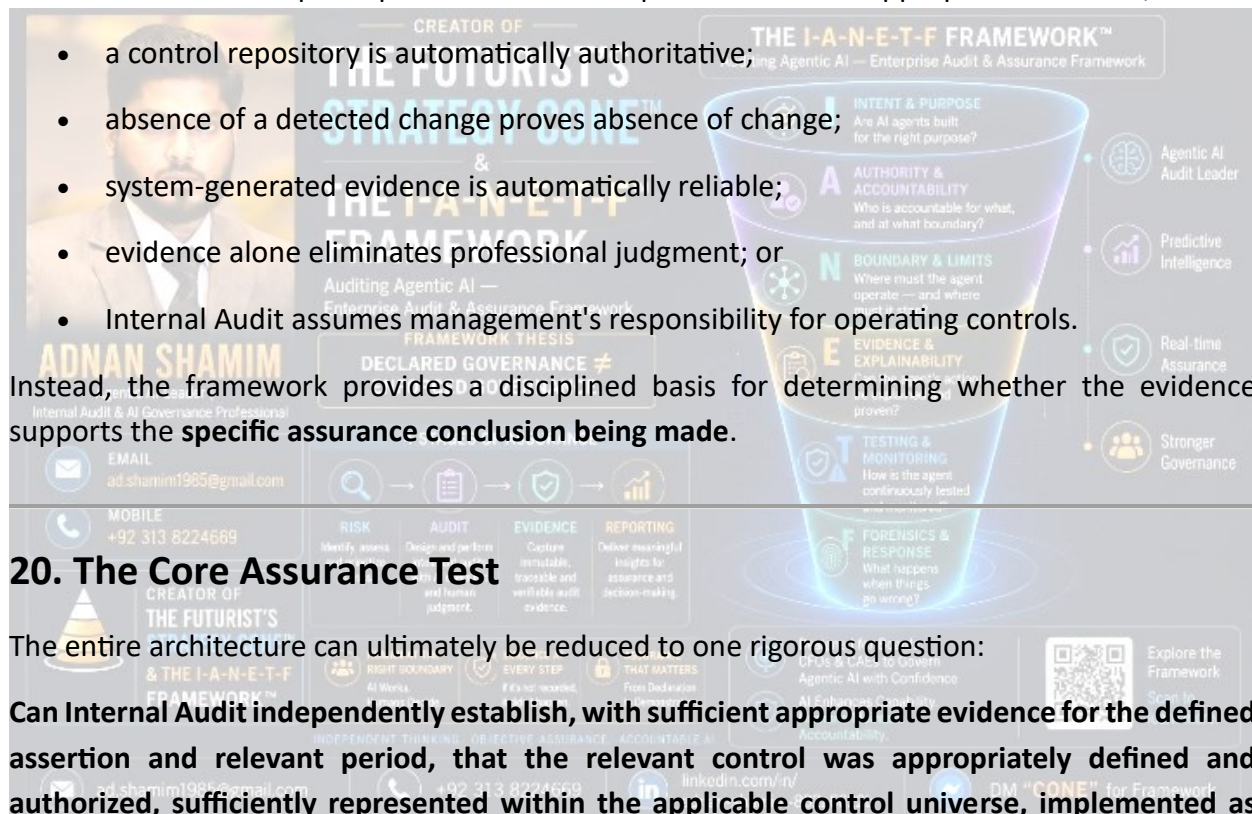
The entire architecture can ultimately be reduced to one rigorous question:

Can Internal Audit independently establish, with sufficient appropriate evidence for the defined assertion and relevant period, that the relevant control was appropriately defined and authorized, sufficiently represented within the applicable control universe, implemented as intended, actually operated within its authorized boundary, and that material changes, exceptions and limitations were identified, evaluated and appropriately reflected in the conclusion?

If yes, the assurance conclusion has an evidentiary foundation.

If no, the limitation must be recognized.

The answer must never be strengthened merely because management expects a positive conclusion.



21. The Fundamental Assurance Principle

The central principle is:

You cannot reliably assure change against an inadequately defined universe. You cannot establish operating effectiveness from documentation alone. You cannot infer sustained operation from a single snapshot. You cannot treat absence of evidence as automatic evidence of absence. You cannot treat system-generated or AI-generated evidence as inherently reliable. And you cannot convert an observed difference into a control conclusion without evaluating the evidence, criteria, context, authorization and risk.

Therefore:

Universe + Criteria + Expected State + Implemented State + Observed State + Evidence + Time + Delta + Independent Validation

must be connected sufficiently to support the stated assurance objective.

No individual element is sufficient by itself.

Conclusion: From Governance on Paper to Governance That Can Be Proven

The maturity of an AI governance environment should not be measured simply by the volume of policies, the size of the control repository, or the number of controls management reports.

The stronger question is:

Can the organization demonstrate that the relevant control universe was appropriately defined for the assurance objective, the expected and observed states were sufficiently established, the evidence was appropriate and reliable, material changes were detectable and evaluated, and Internal Audit could independently support the resulting conclusion?

For Agentic AI, this standard becomes even more important.

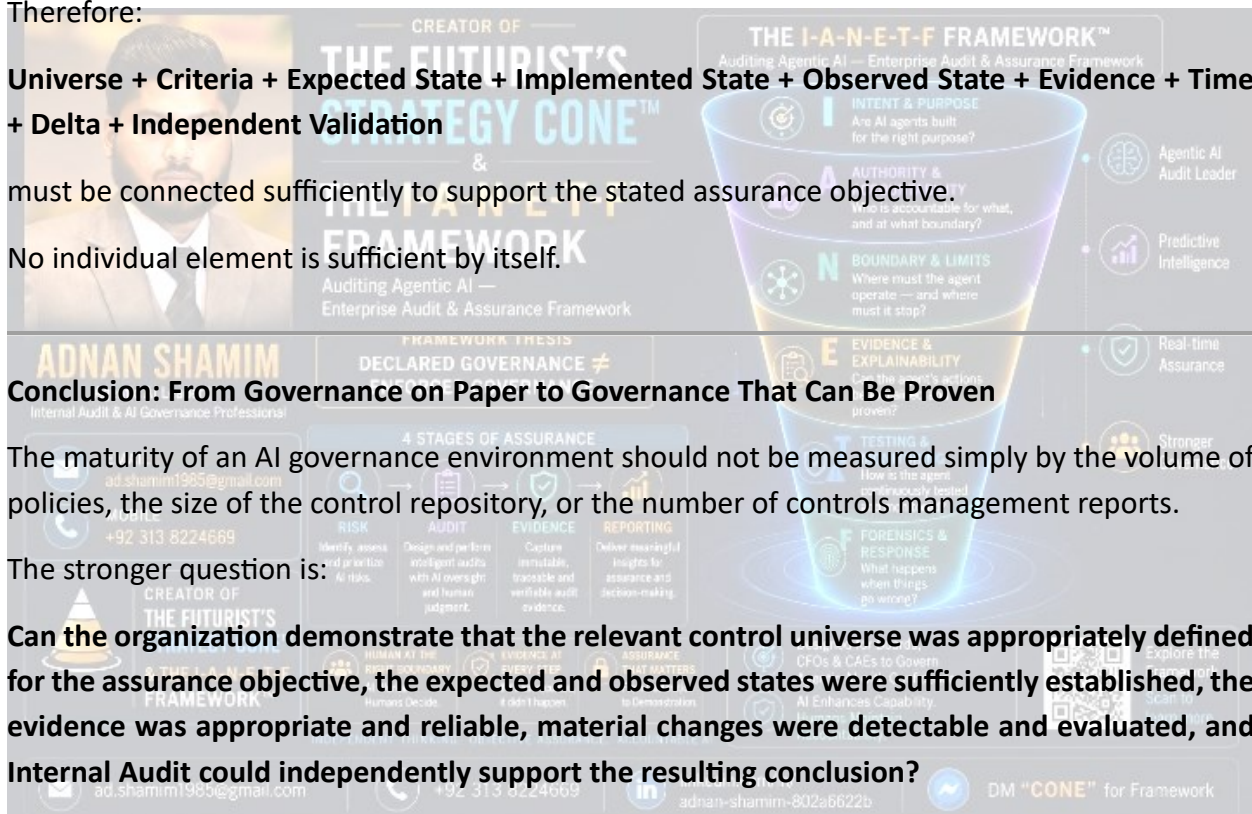
When an AI agent can make decisions, invoke tools, access data, interact with other agents and execute consequential actions, **governance cannot stop at documented intent.**

The assurance chain must extend to demonstrated operation.

Intent defines what should happen.

Governance establishes authority and boundaries.

Controls constrain behavior.



Implementation establishes how controls are deployed.

Execution creates observable states.

Evidence demonstrates what happened.

Comparison identifies meaningful change.

Testing evaluates whether controls operated as required.

Independent Internal Audit determines what the evidence can legitimately support.

That is the transition from:

Documented Governance

to

Demonstrable Governance.

And ultimately from:

“We have a control.”

to the far more demanding assurance statement:

“We can independently demonstrate, to the extent supported by sufficient, appropriate evidence and within the defined scope, criteria and relevant period, that the relevant control was appropriately defined and authorized, sufficiently represented for the assurance objective, implemented and operated within its intended boundary, and that material changes, exceptions and limitations were identified and appropriately evaluated.”

That is not merely control documentation.

That is defensible assurance.



Framework Positioning

The **I-A-N-E-T-F Cone Framework™** does not replace management's governance, risk management, control ownership, regulatory obligations or operational accountability.

It provides an **Internal Audit-oriented assurance chain** for independently evaluating whether the evidence supports the conclusions being made.

The framework does not seek to manufacture certainty.

The objective is to make the assurance conclusion no stronger—and no weaker—than the evidence, criteria, scope and professional evaluation legitimately permit.

The Ultimate Standard

No assertion without a criterion.

No conclusion without appropriate evidence.

No evidence without reliability assessment.

No delta without an appropriate comparison basis.

No finding without sufficient evaluation.

No assurance beyond the evidence.

Governance must not merely be documented. It must be demonstrable.

CREATOR OF THE FUTURIST'S STRATEGY CONE™ & THE I-A-N-E-T-F™ FRAMEWORK
Auditing Agentic AI — Enterprise Audit & Assurance Framework

ADNAN SHAMIM
Agentic AI Leader | Internal Audit & AI Governance Professional

EMAIL: ad.shamim1985@gmail.com
MOBILE: +92 313 8224669

FRAMEWORK THESIS
DECLARED GOVERNANCE ≠ ENFORCED GOVERNANCE.

4 STAGES OF ASSURANCE

- RISK**: Identify, assess and practice AI risks.
- AUDIT**: Design and perform intelligent audits with AI oversight and human judgment.
- EVIDENCE**: Capture immutable, traceable and verifiable audit evidence.
- REPORTING**: Deliver meaningful insights for assurance and decision-making.

THE I-A-N-E-T-F™ FRAMEWORK

- I INTENT & PURPOSE**: Are AI agents built for the right purpose?
- A AUTHORITY & ACCOUNTABILITY**: Who is accountable for what, and at what boundary?
- N BOUNDARY & LIMITS**: Where must the agent operate — and where must it stop?
- E EVIDENCE & EXPLAINABILITY**: Can the agent's actions be explained and proven?
- T TESTING & MONITORING**: How is the agent continuously tested and monitored?
- F FORENSICS & RESPONSE**: What happens when things go wrong?

Agentic AI Audit Leader
Predictive Intelligence
Real-time Assurance
Stronger Governance

DESIGNED FOR BOARDS, CFOs & CAES TO GOVERN AGENTIC AI WITH CONFIDENCE
AI ENHANCES CAPABILITY. HUMANS MAINTAIN ACCOUNTABILITY.

Explore the Framework. Scan to learn more.

INDEPENDENT THINKING. OBJECTIVE ASSURANCE. ACCOUNTABLE AI.

ad.shamim1985@gmail.com | +92 313 8224669 | linkedin.com/in/adnan-shamim-802a6622b | DM "CONE" for Framework